

# QA Testing Documentation

## Salon & SPA Management Platform

**Publisher:** Aveon Infotech Private Limited

**Product owner:** Parvathi Gurusamy

**Version:** 1.0

**Date:** 21 August 2026

This document set is the authoritative QA reference for the Salon & SPA Management platform. It contains the master test plan, ~660 P0/P1 test cases across 22 modules, the release regression checklist, and the defect-reporting template. It is intended for QA engineers, developers, product owners, support, and any auditor requesting evidence of testing rigour.

© 2026 Aveon Infotech Private Limited. All rights reserved.

# Contents

- 0. Overview
- 1. Master Test Plan
- 2. Test Case Catalogue
- 3. Release Regression Checklist
- 4. Defect Report Template

# 0. Overview

# QA Documentation Index

Author: QA Lead, Aveon Infotech Private Limited Last updated: 2026-08-21

## Documents in this folder

| File                   | What it is                                                            | When to read                               |
|------------------------|-----------------------------------------------------------------------|--------------------------------------------|
| <b>TEST_PLAN.md</b>    | Master test plan — scope, strategy, environments, sign-off            | Once at onboarding, again at every release |
| <b>TEST_CASES.md</b>   | Full test-case catalogue organised by module (22 modules, 660+ cases) | While executing a formal QA cycle          |
| <b>REGRESSION.md</b>   | The ordered checklist run before every release                        | Before every production deploy             |
| <b>BUG_TEMPLATE.md</b> | Copy-paste template for filing GitHub issues                          | Every time you file a defect               |

## Quick links

- **Environments:** see TEST\_PLAN §3
- **Personas:** TEST\_PLAN §7.1
- **Tenant-isolation suite** (P0 security): TEST\_PLAN §10.2
- **Sign-off matrix:** TEST\_PLAN §13.2

## Cadence

- **Smoke** (10 min) — after every deploy to any env
- **Regression** (90 min) — before staging→prod promotion
- **Full test-case pass** (5–10 days) — before major releases
- **Security review** — quarterly + before releases touching auth / billing / super-admin
- **Load test** — monthly on staging

## Who to ping

| Situation                            | Ping                         |
|--------------------------------------|------------------------------|
| P0 discovered outside business hours | on-call engineer on WhatsApp |
| Unclear whether P0 vs P1             | QA Lead                      |

|                           |                                             |
|---------------------------|---------------------------------------------|
| Rollback needed           | Engineering Lead                            |
| Billing / payment defect  | Engineering Lead + Product Manager          |
| Data leak between tenants | Security + Engineering Lead + block release |

# 1. Master Test Plan

# Salon & SPA Management — Master Test Plan

**Product:** Salon & SPA Management Software **Publisher:** Aveon Infotech Private Limited **Author:** QA Lead  
**Version:** 1.0 **Last updated:** 2026-08-21

---

## 1. Introduction

### 1.1 Purpose

This document is the authoritative test plan for the Salon & SPA Management platform. It defines what will be tested, how it will be tested, who is responsible, and when a build is releasable. It is written for the QA team, engineers, product owners, and support.

### 1.2 Product summary

A multi-tenant SaaS platform for salons and spas. Every salon that signs up is an isolated **Organization**; users, bookings, staff, sales, memberships and messages are strictly scoped to their org. The platform ships with a public marketing site, a self-serve signup + onboarding wizard, an admin app, a customer portal, an embeddable booking widget, WhatsApp Cloud API automation, Razorpay-backed billing, and an Aveon-side super-admin console with impersonation.

### 1.3 Related documents

- `/README.md` — architecture, tech stack, deploy targets
  - `/DEVELOPMENT_PLAN.md` — engineering roadmap
  - `/FREZKA_ANALYSIS.md` — competitive gap analysis
  - `/SETUP_GUIDE.md` — local dev bootstrap
  - `/docs/testing/TEST_CASES.md` — full P0/P1 test-case catalogue (companion file)
  - `/docs/testing/REGRESSION.md` — per-release regression checklist
  - `/docs/testing/BUG_TEMPLATE.md` — defect reporting template
- 

## 2. Scope

### 2.1 In-scope

- **Public marketing site** — Home, Features, Pricing, About, Blog, Contact, Terms, Privacy, Start-your-salon, public booking widget
- **Authentication & multi-tenancy** — signup, login, refresh tokens, tenant isolation, role hierarchy
- **Onboarding wizard** — first-branch, first-service, first-staff

- **Admin app modules** — Dashboard, Bookings, Branches, Services, Staff, Customers, Memberships, Products, Sales (unified POS), Growth, Referrals, Notification Templates, Access Control, Inquiries, Coupons, Reviews, Reports, Notifications, Settings, Billing, Data & Privacy
- **Customer portal** — My Bookings, My Membership, My Referrals, Notifications, Profile
- **Public booking widget** — `/book/:branchId` and `?embed=1` iframe mode
- **Billing** — Trial banner, Razorpay Subscriptions hosted checkout, webhooks, invoice history, WhatsApp upgrade fallback
- **Plan enforcement** — branch cap, staff cap, WhatsApp monthly quota, feature flags on memberships/referrals/growth kit
- **Super-admin console** — org list, filters, plan/trial/status actions, impersonation, audit log
- **DPDPA compliance** — data export, delete-my-org, terms & privacy pages
- **Integrations** — Cloudinary (uploads), WhatsApp Cloud API, Razorpay Subscriptions
- **API surface** — every REST endpoint under `/api/v1/*` including `/public/*` and `/webhooks/*`

## 2.2 Out-of-scope for v1

- Native mobile apps (only web + PWA behavior)
- Localised UI languages other than English (Hindi/Tamil planned for v1.1)
- Load testing beyond 500 concurrent tenants (see §11.3 for benchmark plan)
- Manual PDF invoice generation (Razorpay-hosted PDFs are used instead)
- SOC 2 / ISO 27001 certification audits (self-attestation only)

## 2.3 Assumptions

- Backend is deployed on Railway with PostgreSQL 15+; frontend on Vercel.
- Cloudinary + WhatsApp Cloud API accounts exist and env vars are set.
- Razorpay account may not be live during initial QA cycles; testing falls back to the WhatsApp-CTA billing flow when `RAZORPAY_KEY_ID` is absent.
- The Default Organization (id `00000000-0000-0000-0000-000000000001`) holds all pre-multi-tenancy data and is on the PRO plan.

## 3. Test environments

| Environment    | URL                                                   | Purpose                         | Data                                       | Access              |
|----------------|-------------------------------------------------------|---------------------------------|--------------------------------------------|---------------------|
| <b>Local</b>   | <code>http://localhost:5173 + :5000</code>            | Dev + unit / integration test   | Seeded fixtures                            | Any dev             |
| <b>Preview</b> | Vercel PR previews                                    | Feature branch review           | Copy of staging                            | Anyone with the URL |
| <b>Staging</b> | <code>staging.salon-management-nine.vercel.app</code> | UAT, regression, load rehearsal | Anonymised prod snapshot, refreshed weekly | Product + QA        |



|                   |                                   |                       |      |                            |
|-------------------|-----------------------------------|-----------------------|------|----------------------------|
| <b>Production</b> | saloon-management-nine.vercel.app | Live customer traffic | Real | Everyone; smoke tests only |
|-------------------|-----------------------------------|-----------------------|------|----------------------------|

**Backend URLs** mirror the frontend on Railway. Migration `bootstrap.ts` runs on every deploy — verify readiness at `/api/v1/health/ready` returns `{"status": "OK", "db": "up"}` before starting any test.

**Never run destructive test data against production.** Use a Local or Staging environment for any test that creates/deletes orgs or subscriptions.

## 4. Test strategy

### 4.1 Test pyramid

```

/\
/ \ ~5% Exploratory + UAT
/----\
/ E2E \ ~15% Cypress / Playwright happy-paths on staging
/-----\
/ Integ. \ ~30% API tests: request → assert response + DB state
/-----\
/ Unit tests \ ~50% Service functions, helpers, validators
/-----\

```

### 4.2 Testing approach per stage

| Stage             | Owner                  | Trigger                    | Blocking?                |
|-------------------|------------------------|----------------------------|--------------------------|
| Unit tests        | Dev                    | Every commit (CI)          | Yes — merge blocked      |
| Integration (API) | Dev + QA               | Every PR (CI)              | Yes                      |
| E2E smoke         | QA                     | Nightly on staging         | Yes for release          |
| Regression        | QA                     | Before release             | Yes for release          |
| Security          | QA + Security          | Before release + quarterly | Yes for release          |
| Performance       | QA + SRE               | Monthly + before major     | No, but reported         |
| Exploratory       | QA + PM                | Every 2 weeks              | No, but findings triaged |
| UAT               | Product + pilot salons | Before major release       | Yes — pilot sign-off     |

### 4.3 Priorities

| Priority             | Definition                                                 | Example                                                                   |
|----------------------|------------------------------------------------------------|---------------------------------------------------------------------------|
| <b>P0 — Critical</b> | Blocks release. Money, data safety, security.              | Cross-tenant data leak, checkout doesn't create subscription, login fails |
| <b>P1 — High</b>     | Blocks a whole workflow. Cosmetic-only exceptions allowed. | Cannot add a booking, WA send fails silently, sidebar broken              |

|                    |                                 |                                              |
|--------------------|---------------------------------|----------------------------------------------|
| <b>P2 — Medium</b> | Degrades UX but has workaround. | Toast wording wrong, chart axis mis-labelled |
| <b>P3 — Low</b>    | Polish.                         | Icon slightly off, hover state missing       |

## 5. Roles & responsibilities

| Role                    | Responsibilities                                                       |
|-------------------------|------------------------------------------------------------------------|
| <b>QA Lead</b>          | Owns this plan. Signs off release.                                     |
| <b>QA Engineer(s)</b>   | Executes test cases, files defects, maintains regression suite.        |
| <b>Engineering Lead</b> | Owns unit + integration coverage. Fixes P0/P1 defects.                 |
| <b>Product Manager</b>  | Owns UAT criteria and pilot-salon feedback.                            |
| <b>Support Lead</b>     | Runs impersonation-based verification post-release.                    |
| <b>DevOps / SRE</b>     | Owns deploy pipeline, staging refresh, performance test harness.       |
| <b>Security</b>         | Reviews auth, tenant isolation, secrets handling before every release. |

## 6. Entry & exit criteria

### 6.1 Entry to formal QA cycle

- All P0/P1 features code-complete on staging
- CI green (unit + integration + type-check + build)
- `bootstrap.ts` migration succeeded on staging DB
- Test data seeded per §7
- Release notes drafted with feature list + known issues

### 6.2 Exit / release criteria

- **Zero open P0** and **zero open P1** defects
- All **P0 test cases pass** on staging (§9)
- Regression suite green (`/docs/testing/REGRESSION.md`)
- Security checklist signed off (§10.2)
- Two pilot salons UAT-signed-off
- Rollback plan documented + tested

## 7. Test data & personas

### 7.1 Personas

The system supports six user roles. Every test-case section maps to at least one persona.

| Persona                   | Role       | Where they log in              | What they do                                                    |
|---------------------------|------------|--------------------------------|-----------------------------------------------------------------|
| <b>Rhea (Owner)</b>       | OWNER      | /start-salon → login           | Signs up, onboards, sets up branches/services, upgrades to paid |
| <b>Anita (Admin)</b>      | ADMIN      | /login                         | Manages catalog, staff, reports, billing                        |
| <b>Vikram (Manager)</b>   | MANAGER    | /login                         | Runs POS shift, collects payment, edits bookings                |
| <b>Karan (Staff)</b>      | STAFF      | /login                         | Views only own bookings + earnings, sees only own commission    |
| <b>Divya (Customer)</b>   | CUSTOMER   | /login or /book/:branch Id     | Books, sees own history, refers friends                         |
| <b>Ravi (Super-admin)</b> | SUPERADMIN | /login (SUPERADMIN_EMAILS env) | Manages every tenant, impersonates, audits                      |

### 7.2 Seeded fixtures

| Fixture org          | Slug         | Plan                      | Purpose                                       |
|----------------------|--------------|---------------------------|-----------------------------------------------|
| Default Organization | default      | PRO                       | Holds pre-multi-tenancy data — never delete   |
| QA Alpha             | qa-alpha     | GROWTH                    | Positive tests for GROWTH-tier features       |
| QA Beta              | qa-beta      | STARTER                   | Positive tests for STARTER, hits caps quickly |
| QA Trial             | qa-trial     | TRIAL                     | Trial banner + expiry testing                 |
| QA Suspended         | qa-suspended | STARTER, status SUSPENDED | Login refusal + reactivation                  |

Each org has  $\geq 1$  branch,  $\geq 3$  services,  $\geq 3$  staff,  $\geq 5$  customers,  $\geq 10$  bookings across statuses.

### 7.3 Never commit these

- Real Razorpay keys, JWT secrets, Cloudinary secrets, WhatsApp tokens

- Real customer PII in fixtures — use `test.user+###@aveon.example`

## 8. Test types

### 8.1 Smoke test (~10 min)

Run after every deploy to any environment. See `REGRESSION.md` → `SMOKE_SUITE` for the current 12-step recipe.

Minimum smoke steps:

1. `/api/v1/health/ready` returns `db:up`
2. Public marketing home renders, no console errors, LCP <2.5s
3. Register a new OWNER via `/start-salon` → land on `/onboarding`
4. Login as seeded ADMIN → land on `/dashboard`, see KPI tiles rendering
5. Create a Branch, Service, Staff, Customer (one of each)
6. Create a Booking with existing customer
7. Take a walk-in Sale from POS
8. Send a WhatsApp test message (if configured)
9. Open `/billing` — plan card + usage bars render
10. As SUPERADMIN visit `/super-admin` — orgs list loads
11. Impersonate an org owner → banner shows → return-to-admin works
12. Data export downloads a JSON file

### 8.2 Functional

Detailed per-module test cases live in `/docs/testing/TEST_CASES.md`. This document (§9) summarises coverage areas.

### 8.3 Regression

Ordered checklist executed before every release. Owned by QA Lead. See `REGRESSION.md`.

### 8.4 Security

See §10.

### 8.5 Performance

See §11.

### 8.6 Accessibility

- Lighthouse Accessibility score ≥ 90 on public marketing pages

- Keyboard-only navigation possible through booking widget
- Screen-reader labels on all icon-only buttons

## 8.7 Compatibility

| Category  | Coverage matrix                                                              |
|-----------|------------------------------------------------------------------------------|
| Browsers  | Chrome 120+, Edge 120+, Safari 17+, Firefox 121+, Chrome Android, Safari iOS |
| Viewports | 360×640 (mobile), 768×1024 (tablet), 1440×900 (desktop), 1920×1080 (wide)    |
| OS        | Windows 11, macOS 14+, Android 12+, iOS 17+                                  |
| Print     | Receipt (Ship 4B) on 80mm thermal printers                                   |

## 8.8 Exploratory

Bi-weekly 90-minute session per QA engineer, charter written before, notes captured in `/docs/testing/exploratory/YYYY-MM-DD.md`.

## 8.9 UAT

Two pilot salons run 5 real transactions each per release on staging before promotion to production.

# 9. Test coverage by module (summary)

Detailed cases are in `TEST_CASES.md`. Numbers below are minimum P0/P1 cases per module.

| Module                                                                  | Ship | P0 | P1 | Cross-refs       |
|-------------------------------------------------------------------------|------|----|----|------------------|
| Marketing site<br>(Home, Features,<br>Pricing, About,<br>Blog, Contact) | —    | 8  | 20 | SEO, a11y        |
| Legal pages<br>(Terms, Privacy)                                         | 6    | 2  | 4  | Compliance       |
| Public booking<br>widget                                                | —    | 12 | 15 | Tenant isolation |
| Signup + Start-your-<br>salon                                           | 2B   | 10 | 12 | Multi-tenancy    |
| Onboarding wizard                                                       | 2B   | 8  | 10 | —                |
| Login / logout /<br>refresh                                             | 1A   | 6  | 8  | Security         |
| Dashboard KPI tiles                                                     | —    | 4  | 8  | Tenant isolation |

|                                             |              |    |    |                                |
|---------------------------------------------|--------------|----|----|--------------------------------|
| Bookings (table + calendar + staff grid)    | —            | 15 | 25 | —                              |
| Branches CRUD                               | —            | 6  | 8  | Plan enforcement               |
| Services CRUD                               | —            | 6  | 8  | —                              |
| Staff CRUD + photo upload                   | —            | 8  | 12 | Plan enforcement, Cloudinary   |
| Customers CRUD                              | —            | 5  | 8  | Role scoping                   |
| Sales (unified POS)                         | 2/3/4        | 20 | 30 | Barcode scanner, thermal print |
| Memberships                                 | —            | 6  | 10 | Feature-flag gate              |
| Products + stock                            | —            | 8  | 12 | —                              |
| Coupons                                     | —            | 5  | 8  | —                              |
| Growth toolkit (rebook/win-back/birt hdays) | —            | 5  | 8  | Feature-flag gate              |
| Referrals                                   | —            | 5  | 8  | Feature-flag gate              |
| Notification Templates                      | —            | 3  | 6  | —                              |
| WhatsApp automation                         | 5 (features) | 8  | 12 | Quota metering                 |
| Reports                                     | —            | 6  | 10 | Tenant isolation               |
| Settings (all tabs)                         | —            | 12 | 20 | —                              |
| Access Control                              | —            | 4  | 6  | —                              |
| Inquiries (public POST + admin inbox)       | —            | 4  | 6  | —                              |
| Reviews                                     | —            | 3  | 5  | —                              |
| Payouts + Staff Earnings                    | —            | 6  | 10 | Role scoping                   |
| Notifications (in-app)                      | —            | 3  | 5  | —                              |
| Customer portal /my/*                       | —            | 10 | 15 | Role scoping                   |
| Trial banner + Billing UI                   | 3A           | 8  | 10 | —                              |
| Razorpay checkout + webhook                 | 3B           | 12 | 15 | Payment integrity              |
| Plan enforcement — branch/staff caps        | 4A           | 6  | 8  | —                              |
| WhatsApp quota metering                     | 4B           | 6  | 8  | —                              |
| Feature-flag gates                          | 4C           | 8  | 12 | —                              |

|                                  |    |            |            |                 |
|----------------------------------|----|------------|------------|-----------------|
| Super-admin dashboard            | 5A | 12         | 15         | Cross-tenant    |
| Impersonation                    | 5B | 10         | 12         | Security, audit |
| Data & Privacy — export + delete | 6  | 8          | 10         | DPDPA           |
| <b>Totals</b>                    |    | <b>267</b> | <b>399</b> | —               |

## 10. Security testing

### 10.1 Threat model

| Threat                  | Mitigation in code                                                            | Test                   |
|-------------------------|-------------------------------------------------------------------------------|------------------------|
| Cross-tenant read leak  | Prisma extension (Ship 1B) auto-injects <code>where.organizationId</code>     | §10.2 iso-01 to iso-08 |
| Cross-tenant write leak | Same extension + <code>assertCurrentUserOrg</code> helper                     | iso-09 to iso-14       |
| Broken auth             | JWT signature verified server-side; refresh tokens stored in DB               | sec-01 to sec-06       |
| Privilege escalation    | <code>authorize()</code> middleware; OWNER treated as ADMIN implicitly only   | sec-07 to sec-12       |
| Impersonation abuse     | Every impersonation writes an AuditLog row                                    | sec-13 to sec-15       |
| Webhook forgery         | Razorpay HMAC-SHA256 signature verified before any DB write                   | sec-16                 |
| Secret leak             | <code>.env</code> gitignored; frontend never receives <code>JWT_SECRET</code> | sec-17                 |
| XSS                     | React auto-escaping + no <code>dangerouslySetInnerHTML</code> on user data    | sec-18                 |
| SQLi                    | Prisma parameterises everything                                               | sec-19                 |
| CSRF                    | JWT in Authorization header (not cookie)                                      | sec-20                 |
| Trial abuse             | Same phone check at signup (planned Ship 7)                                   | sec-21                 |

### 10.2 Tenant isolation suite

Executed by two seeded orgs (QA Alpha + QA Beta) with distinct users.

| ID     | Test                                                        | Expected                                                                                                         |
|--------|-------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| iso-01 | Alpha user calls GET /branches                              | Only Alpha's branches                                                                                            |
| iso-02 | Alpha user calls GET /branches/:betaBranchId                | 404 (or forbidden)                                                                                               |
| iso-03 | Alpha user calls PATCH /branches/:betaBranchId              | 403/404, no mutation                                                                                             |
| iso-04 | Alpha user calls POST /bookings with a Beta customerId      | 400 (validation) or the booking is created with customerId=null (walk-in fallback) — never Beta customer visible |
| iso-05 | Alpha user calls GET /customers?limit=1000                  | Beta customers absent from results                                                                               |
| iso-06 | Alpha user searches GET /products?search=<beta unique term> | Zero results                                                                                                     |
| iso-07 | Alpha reports (GET /reports/*)                              | Zero rows from Beta                                                                                              |
| iso-08 | Alpha GET /organizations/me returns Alpha's row only        | ✓                                                                                                                |
| iso-09 | Alpha POST /branches                                        | new branch has organizationId=Alpha                                                                              |
| iso-10 | Alpha POST /products                                        | new product has organizationId=Alpha                                                                             |
| iso-11 | Alpha POST /bookings                                        | new booking has organizationId=Alpha                                                                             |
| iso-12 | Alpha POST /whatsapp/messages/test targeting a phone        | UsageMeter row is (Alpha, YYYY-MM), not Beta                                                                     |
| iso-13 | Alpha DELETE any resource id from Beta                      | 404 (extension can't scope delete-by-id — verify service-level check)                                            |
| iso-14 | SUPERADMIN issues GET /super-admin/organizations            | Returns both Alpha and Beta (cross-tenant intentional)                                                           |
| iso-15 | Non-SUPERADMIN calls /super-admin/*                         | 403 for every route                                                                                              |

**\*\*Any iso-\* failure blocks release.\*\*** A single cross-tenant leak invalidates the platform.

### 10.3 Pre-release security checklist

- ■ .env files not committed
- ■ SUPERADMIN\_EMAILS contains only real Aveon staff
- ■ JWT\_SECRET / JWT\_REFRESH\_SECRET are 32+ chars and differ
- ■ Razorpay Webhook Secret set + HMAC verify enforced
- ■ CORS\_ORIGIN allow-list matches only known frontend domains



- ■ Rate limiter active (`app.use(limiter)`)
- ■ All `authorize(...)` calls include the intended role list
- ■ No `console.log` of tokens / secrets in prod builds
- ■ Cloudinary API secret not exposed to the browser bundle
- ■ Impersonation audit rows created on every impersonate call

## 11. Non-functional testing

### 11.1 Performance targets (per user session on Vercel + Railway)

| Metric                           | Target        | Measured on                       |
|----------------------------------|---------------|-----------------------------------|
| API p50 latency (list endpoints) | < 200 ms      | /bookings?limit=50                |
| API p95 latency                  | < 600 ms      | Same                              |
| Dashboard first paint            | < 2.5 s       | Chrome DevTools throttled Fast 3G |
| Public marketing LCP             | < 2.0 s       | Lighthouse desktop                |
| POS checkout end-to-end          | < 3 s         | Booking → payment → receipt       |
| DB pool utilisation              | < 60% average | Railway metrics                   |

### 11.2 Load testing

Monthly, on staging, with k6 or Artillery:

- **Baseline:** 50 concurrent tenants, 10 req/s each = 500 req/s sustained for 10 min
- **Spike:** burst to 2000 req/s for 30 s
- Success criteria: no 5xx, p95 < 1.5 s, no DB pool exhaustion

### 11.3 Scale ceiling

Current architecture (single Postgres, single Node process on Railway) is comfortable to ~500 active tenants. Beyond that: add read replicas + horizontal scale.

### 11.4 Accessibility (WCAG 2.1 AA)

- Colour contrast  $\geq 4.5:1$  on body text
- Every interactive element focusable + visible focus ring
- Icon-only buttons have `title` or `aria-label`
- Skip-to-content link on marketing pages

## 12. Defect management

## 12.1 Where

GitHub Issues in the `Saloon_Management` repo. Label taxonomy:

- Type: `bug`, `regression`, `security`, `perf`, `a11y`
- Priority: `P0`, `P1`, `P2`, `P3`
- Ship: `ship-1a` ... `ship-6`
- Module: `bookings`, `sales`, `billing`, `super-admin`, etc.

## 12.2 SLA

| Priority | Ack    | Fix on staging | Fix in prod       |
|----------|--------|----------------|-------------------|
| P0       | 30 min | 4 h            | Same day          |
| P1       | 4 h    | 1 day          | Next release      |
| P2       | 1 day  | 5 days         | Bi-weekly release |
| P3       | 1 week | 30 days        | Next quarter      |

## 12.3 Defect template

See `BUG_TEMPLATE.md`.

# 13. Sign-off & release

## 13.1 Release cadence

- Feature releases: bi-weekly on Wednesdays
- Hotfixes: any time, must clear smoke + P0 tenant-isolation suite

## 13.2 Sign-off matrix

| Role             | Signs off on                                   |
|------------------|------------------------------------------------|
| QA Lead          | Regression suite pass + release notes accurate |
| Engineering Lead | CI green + rollback plan tested                |
| Security         | Checklist §10.3                                |
| Product Manager  | UAT sign-off from two pilot salons             |
| Support Lead     | Support-facing changes documented              |

## 13.3 Rollback

Every deploy has a git SHA. Rollback is a Vercel/Railway one-click to previous SHA. Migrations should be reviewed for **rollback-safety** at PR time (never drop columns without a two-deploy plan).

## 14. Appendix

### 14.1 Quick reference URLs

| Purpose               | URL                                       |
|-----------------------|-------------------------------------------|
| Production frontend   | https://saloon-management-nine.vercel.app |
| Production API        | https://<railway-domain>/api/v1           |
| Health                | /api/v1/health/ready                      |
| Public booking widget | /book/:branchId                           |
| Super-admin           | /super-admin                              |
| Data export           | /data-privacy (in-app) → download         |
| Razorpay webhook      | POST /api/v1/webhooks/razorpay            |

### 14.2 Companion docs

- Detailed test cases: **TEST\_CASES.md**
- Regression checklist: **REGRESSION.md**
- Bug template: **BUG\_TEMPLATE.md**

---

*End of Master Test Plan — Version 1.0*

## 2. Test Case Catalogue

# Salon & SPA Management — Test Case Catalogue

Companion to `TEST_PLAN.md`. Every case follows this shape:

- **ID** — unique, prefixed by module (e.g. `POS-01`, `SEC-04`)
- **Priority** — P0 (release blocker) · P1 · P2 · P3
- **Preconditions** — state required before executing
- **Steps** — 1., 2., 3. ...
- **Expected** — one sentence per assertion
- **Notes** — env / role / data caveats

Test data personas match `TEST_PLAN.md` §7.

---

## Table of contents

1. Auth & multi-tenancy (AUTH)
2. Marketing site (MKT)
3. Public booking widget (WGT)
4. Signup + onboarding (SGN)
5. Bookings (BKG)
6. Unified Sales POS (POS)
7. Staff (STF)
8. Branches (BRN)
9. Products & stock (PRD)
10. Memberships (MEM)
11. Coupons (COU)
12. WhatsApp automation (WA)
13. Growth toolkit (GRW)
14. Referrals (REF)
15. Reports (RPT)
16. Billing & plan enforcement (BIL)
17. Razorpay checkout (RZP)
18. Super-admin (ADM)
19. Impersonation (IMP)
20. Data & Privacy — DPDPA (DPP)

21. Customer portal (CST)

22. Security cross-cutting (SEC)

## 1. Auth & multi-tenancy (AUTH)

### ***AUTH-01 — Login happy path · P0***

**Pre:** Seeded ADMIN user of QA Alpha org exists. **Steps:**

1. Navigate to `/login`
2. Enter valid email + password → **Login**

**Expected:** 200 from `POST /auth/login`; access + refresh tokens saved; land on `/dashboard`; nav shows correct email; `organization-me` query returns QA Alpha.

### ***AUTH-02 — Login wrong password · P0***

**Steps:** valid email, wrong password. **Expected:** 401 with message *"Invalid email or password"*; no tokens saved; no user session state.

### ***AUTH-03 — Login for SUSPENDED user · P1***

**Pre:** User whose `org.status` = SUSPENDED. **Expected:** Login refused with meaningful error; user stays on `/login`.

### ***AUTH-04 — Access token expiry + refresh · P0***

**Steps:** Log in. Manually expire the access token (edit `localStorage`). Hit any authed endpoint. **Expected:** Interceptor calls `/auth/refresh-token`, receives new pair, retries original request, succeeds.

### ***AUTH-05 — Refresh token revoked · P1***

**Steps:** Log in. Delete the refresh token row from DB. Trigger a refresh. **Expected:** 401; user redirected to `/login`; `localStorage` cleared.

### ***AUTH-06 — JWT includes organizationId · P0***

**Steps:** Log in as an ADMIN of QA Alpha. Decode the access token payload. **Expected:** `payload.organizationId` matches QA Alpha's id.

### ***AUTH-07 — SUPERADMIN auto-promotion · P0***

**Pre:** `SUPERADMIN_EMAILS` env includes `qa+super@aveon.example`. **Steps:** Register that user, or log in an existing user with that email. **Expected:** DB row `role` = SUPERADMIN after first login; JWT reflects the new role.

### ***AUTH-08 — Role hierarchy: OWNER implicit ADMIN · P1***

**Steps:** Log in as OWNER (created via `/start-salon`). Attempt every ADMIN-guarded route. **Expected:** All ADMIN routes accessible; OWNER never blocked from their own tenant.

### ***AUTH-09 — Tenant frame set before service code · P0***

**Steps:** Add temporary logging to a service to print `getCurrentOrgId()`. Hit any endpoint. **Expected:** Non-null orgId matching JWT's `organizationId`.

### ***AUTH-10 — Logout clears refresh token · P1***

**Steps:** Log in, hit **Logout**. **Expected:** DB `refreshTokens` row deleted; `localStorage` cleared; user redirected to `/login`.

### ***AUTH-11 — Multi-tab session · P2***

**Steps:** Log in in Tab A. Log out in Tab B. Reload Tab A. **Expected:** Tab A also detects logout on next request (401 → forced redirect).

---

## **2. Marketing site (MKT)**

### ***MKT-01 — Home page loads · P0***

**Steps:** Anonymous → visit `/`. **Expected:** Hero renders; no console errors; Sparkles chip visible; primary CTAs Start free trial / See it in action.

### ***MKT-02 — Features tabs · P1***

**Steps:** Click each tab in the Product Showcase section. **Expected:** Content swaps with fade motion; browser URL bar unchanged; no re-render loops.

### ***MKT-03 — Currency toggle on Pricing · P1***

**Steps:** Visit `/pricing`. Toggle INR / USD / GBP / AED. **Expected:** Prices update; GST hint shown only when INR selected.

### ***MKT-04 — Annual toggle · P1***

**Steps:** Toggle Monthly ↔ Annual. **Expected:** Prices × 10 (2 months free), suffix changes to `/year`.

### ***MKT-05 — Blog list + post · P1***

**Steps:** `/blog` → click any post. **Expected:** All 5 seeded posts visible; post detail renders with author card (Parvathi Gurusamy); related posts shown.

### ***MKT-06 — Contact form → mailto · P2***

**Steps:** Fill Contact form and submit. **Expected:** Opens mail client with pre-filled body; success screen after.

### ***MKT-07 — SEO meta tags per page · P1***

**Steps:** View source of Home, Features, Pricing, About, Blog, Contact. **Expected:** Unique <title> and <meta description> per page; keywords include *Salon Management*, *SPA Management*, etc.; JSON-LD SoftwareApplication schema present on Home.

### ***MKT-08 — Legal pages · P1***

**Steps:** /legal/terms and /legal/privacy. **Expected:** Both render; footer links work; effective date shown; contact fields present.

### ***MKT-09 — Sitemap + robots · P0***

**Steps:** GET /sitemap.xml and /robots.txt on production. **Expected:** Both 200; sitemap lists 11 URLs; robots blocks /dashboard, /bookings, etc.

### ***MKT-10 — Mobile responsiveness · P1***

**Steps:** Resize to 360×640 across all marketing pages. **Expected:** No horizontal scroll; sticky nav collapses to hamburger; hero remains legible.

---

## **3. Public booking widget (WGT)**

### ***WGT-01 — Widget loads by branch id · P0***

**Steps:** /book/<valid-branchId>. **Expected:** 5-step wizard renders; salon name + address shown; no login required.

### ***WGT-02 — Widget with invalid branch id · P1***

**Steps:** /book/000000000-0000-0000-0000-000000000000. **Expected:** Friendly "Booking page unavailable" message.

### ***WGT-03 — Step 1 Service selection · P0***

**Steps:** Pick a service. **Expected:** Advances to Step 2; sub-header shows service name.

### ***WGT-04 — Step 2 Staff selection · P0***

**Steps:** Pick a stylist. **Expected:** Only verified staff who offer that service appear.

### ***WGT-05 — Step 3 Date picker · P1***

**Steps:** Pick a date. **Expected:** 14-day chip grid; Today / Tomorrow labels correct; past dates absent.

### ***WGT-06 — Step 4 Slot generation · P0***

**Steps:** Pick a date and staff for a busy day. **Expected:** Slots between branch open/close; slots overlapping existing bookings marked unavailable and disabled; on today's date, past slots hidden.



### **WGT-07 — Step 5 Contact + submit · P0**

**Steps:** Fill name + phone, submit. **Expected:** POST `/public/bookings` returns 200; success screen shows reference BK...; booking created with `status=PENDING`, walk-in fields set.

### **WGT-08 — Widget in embed mode · P1**

**Steps:** `/book/:id?embed=1`. **Expected:** Sticky salon header hidden; footer "Powered by" hidden; wizard renders inside `<iframe>` test container.

### **WGT-09 — Cross-tenant leak via widget · P0 (SECURITY)**

**Steps:** As anonymous, list services via `/public/branches/<alphaBranchId>/services`. **Expected:** Only Alpha's services returned; no Beta services in response.

### **WGT-10 — Rate limit on POST /public/bookings · P1**

**Steps:** POST 30 bookings from same IP in 60 s. **Expected:** After N (per rate limiter config), 429 Too Many Requests.

### **WGT-11 — Slot generation performance · P2**

**Steps:** Call `/public/branches/:id/slots?...` for branches with 200+ bookings on the day. **Expected:** < 300 ms server response.

### **WGT-12 — Widget booking shows in admin Bookings · P0**

**Steps:** After WGT-07, log in as ADMIN of that branch's org, open `/bookings`. **Expected:** New PENDING booking visible with the walk-in name; status can be flipped to CONFIRMED.

---

## **4. Signup + onboarding (SGN)**

### **SGN-01 — Start-your-salon happy path · P0**

**Steps:** `/start-salon` → fill all fields → **Start free trial**. **Expected:** 200; tokens stored; land on `/onboarding`; a new Organization created with plan TRIAL and 14-day `trialEndsAt`; a new User with role OWNER attached.

### **SGN-02 — Duplicate email · P1**

**Steps:** Signup with an already-registered email. **Expected:** 400 "Email already registered"; form stays with fields.

### **SGN-03 — Slug collision auto-suffix · P2**

**Steps:** Two consecutive signups with the same salon name. **Expected:** Both succeed with distinct slugs (base + random suffix on the second).

### ***SGN-04 — Reserved slug guard · P1***

**Steps:** Attempt salon name "Admin" or "Api". **Expected:** Signup succeeds but slug is `admin-salon-<rand>` (never the raw reserved value).

### ***SGN-05 — Country/currency defaults · P1***

**Steps:** Pick each country flag. **Expected:** Currency inferred correctly (India→INR, US→USD, UK→GBP, UAE→AED, CA→CAD).

### ***SGN-06 — Onboarding wizard – branch step · P0***

**Pre:** Fresh OWNER, no branch yet. **Steps:** On `/onboarding`, complete Step 2 (branch). **Expected:** Branch created via `POST /branches`; next step unlocks.

### ***SGN-07 — Onboarding wizard – service step · P0***

**Steps:** Add first service with price 500 + duration 45. **Expected:** Service created; success screen shown.

### ***SGN-08 — Onboarding wizard skip on completed org · P1***

**Pre:** Org already has  $\geq 1$  branch and  $\geq 1$  service. **Steps:** Manually navigate to `/onboarding`. **Expected:** Immediate redirect to `/dashboard`.

### ***SGN-09 — Onboarding fails gracefully with no cities loaded · P2***

**Pre:** DB missing city seed. **Steps:** Reach branch step. **Expected:** Fallback message *"No cities loaded — the first one available will be used."*; still submittable (backend accepts any cityId or errors clearly).

### ***SGN-10 — CUSTOMER signup attaches to Default Org · P0***

**Steps:** Register with role CUSTOMER via `/register`. **Expected:** DB `user.organizationId` = Default Org id; no new Organization created.

---

## **5. Bookings (BKG)**

### ***BKG-01 — Create booking with registered customer · P0***

### ***BKG-02 — Create walk-in booking (no customer) · P0***

### ***BKG-03 — Cannot create booking overlapping same staff slot · P0***

### ***BKG-04 — Booking status flow PENDING → CONFIRMED → COMPLETED · P0***

### ***BKG-05 — Cancel booking with reason · P1***

### ***BKG-06 — NO\_SHOW status · P1***

**BKG-07 — Coupon applied at creation · P1**

**BKG-08 — Member price applied when customer has active membership · P1**

**BKG-09 — Booking triggers WhatsApp confirmation (if configured) · P1**

**BKG-10 — Booking triggers in-app notification to assigned staff · P1**

**BKG-11 — Table view shows correct filters · P1**

**BKG-12 — Calendar view drag-reschedule · P1**

**BKG-13 — Staff-grid day view shows every staff column · P1**

**BKG-14 — Tenant isolation: cannot fetch other org's booking by id · P0**

**BKG-15 — CUSTOMER can list only own bookings via `/bookings` · P0**

(For brevity the detail template applies; each case documents Pre/Steps/Expected as in AUTH-1.)\*

---

## 6. Unified Sales POS (POS)

**POS-01 — Add product to cart, quick-pay Cash · P0**

**POS-02 — Add service to cart, walk-in name, pay UPI · P0**

**POS-03 — Mixed cart (product + service) single checkout · P0**

**POS-04 — Attach pending booking · P0**

**POS-05 — Duplicate-attach guard · P0**

**POS-06 — Customer name/phone auto-populate on attach · P1**

**POS-07 — Staff name shown on service line · P1**

**POS-08 — GST toggle adds 18% server-side · P0**

**POS-09 — Discount prorated across product / service ticket · P1**

**POS-10 — Receipt modal opens after checkout · P0**

**POS-11 — Receipt print (`window.print`) produces 80mm thermal layout · P1**

**POS-12 — Auto-print toggle triggers print automatically · P2**

**POS-13 — WhatsApp receipt link opens with pre-filled text · P2**

**POS-14 — Barcode scanner adds correct product to cart · P1 (needs USB scanner)**

**POS-15 — Barcode not found — friendly toast · P2**

**POS-16 — Barcode scanning ignored while typing in input · P1**

**POS-17 — Cart persists across page refresh per branch · P1**

**POS-18 — Legacy booking with paymentStatus=PAID doesn't appear in pending list · P1**

**POS-19 — Attempt to pay already-paid booking → line removed, list refetched · P1**

**POS-20 — Stock decremented after product sale · P0**

*(Detail follows same template. Any P0 fail blocks release.)*

---

## **7. Staff (STF)**

**STF-01 — Create staff with photo upload · P0**

**STF-02 — Photo upload > 5 MB rejected · P1**

**STF-03 — Cloudinary URL persisted · P1**

**STF-04 — Unverified staff badge count on sidebar · P2**

**STF-05 — Staff edit — full modal · P1**

**STF-06 — Monthly target field accepts decimal · P1**

**STF-07 — STARTER plan: 4th staff hits 402 with upgrade CTA · P0**

**STF-08 — Cannot see other org's staff (tenant isolation) · P0**

---

## **8. Branches (BRN)**

**BRN-01 — Create branch · P0**

**BRN-02 — City picker loads options · P1**

***BRN-03 — STARTER plan: 2nd branch hits 402 · P0***

***BRN-04 — Booking link modal shows URL + copy button · P1***

***BRN-05 — Embed snippet copyable · P2***

---

## **9. Products & stock (PRD)**

***PRD-01 — Create product with per-branch stock rows · P0***

***PRD-02 — Low-stock badge appears when stock < 5 · P1***

***PRD-03 — Expiring product alert · P2***

***PRD-04 — Stock decremented on POS sale · P0***

***PRD-05 — Stock restored on POS void · P1***

---

## **10. Memberships (MEM)**

***MEM-01 — Create membership plan · P0 · Blocked on STARTER (verify 402)***

***MEM-02 — Assign membership to customer · P0***

***MEM-03 — Member price auto-applied at booking · P1***

***MEM-04 — Member price auto-applied at POS · P1***

***MEM-05 — Reads still work on STARTER (list existing plans) · P1***

***MEM-06 — Writes rejected on STARTER · P0***

---

## **11. Coupons (COU)**

***COU-01 — Create percentage coupon · P0***

***COU-02 — Create fixed-amount coupon · P0***

***COU-03 — Usage limit enforced atomically · P0***

**COU-04 — Per-customer restriction · P1**

**COU-05 — Expired coupon rejected · P1**

---

## 12. WhatsApp automation (WA)

**WA-01 — `/messaging/status` reflects env vars · P1**

**WA-02 — Test send delivers to a verified test number · P0 (requires WA account)**

**WA-03 — `sendText` increments `UsageMeter` on success · P0**

**WA-04 — `sendText` does NOT increment on API failure · P0**

**WA-05 — At quota cap, 402 with details · P0**

**WA-06 — Booking creation fires best-effort WA confirmation · P1**

**WA-07 — WA never blocks booking creation on failure · P0**

---

## 13. Growth toolkit (GRW)

**GRW-01 — Rebook list shows correct customers · P1**

**GRW-02 — Win-back list · P1**

**GRW-03 — Birthday list on current date · P1**

**GRW-04 — WhatsApp deep-link opens with template · P1**

**GRW-05 — Whole `/marketing` router 402s on STARTER plan · P0**

---

## 14. Referrals (REF)

**REF-01 — Customer sees own code on `/my/referrals` · P1**

**REF-02 — Ref code in signup URL tracked · P0**

**REF-03 — First completed booking awards 100 pts to both parties · P0**

**REF-04 — Admin `/referrals` list 402s on STARTER · P0**

**REF-05 — Idempotent — no double-award on repeat COMPLETED transitions · P0**

---

## 15. Reports (RPT)

**RPT-01 — Dashboard revenue formula correct (excludes CANCELLED / NO\_SHOW) · P0**

**RPT-02 — 30-day trend chart renders · P1**

**RPT-03 — Filter by branch scopes results · P1**

**RPT-04 — CUSTOMER role blocked from Reports · P0**

**RPT-05 — Cross-tenant leak check on Reports · P0**

---

## 16. Billing & plan enforcement (BIL)

**BIL-01 — Trial banner shows N days remaining · P1**

**BIL-02 — Banner turns amber at  $\leq 3$  days · P1**

**BIL-03 — Banner turns red on expiry, dismiss disabled · P1**

**BIL-04 — Billing page current-plan card accurate · P0**

**BIL-05 — Usage bars accurate for branch / staff / WA · P1**

**BIL-06 — 402 toast on any capped action · P0**

**BIL-07 — Sidebar crown icon on locked feature (STARTER) · P2**

**BIL-08 — WhatsApp fallback CTA when Razorpay not configured · P1**

---

## 17. Razorpay checkout (RZP)

*(Executable only when Razorpay creds present; skip otherwise.)*

- RZP-01** — `/billing/status` *reflects configured state* · P1
- RZP-02** — **POST** `/billing/subscribe` *returns short\_url* · P0
- RZP-03** — *Duplicate subscribe returns existing sub, not new* · P1
- RZP-04** — *Webhook signature verify: valid* → 200 · P0
- RZP-05** — *Webhook signature verify: invalid* → 401 · P0
- RZP-06** — *subscription.charged flips org.plan* · P0
- RZP-07** — *subscription.cancelled sets status CANCELLED* · P0
- RZP-08** — *invoice.paid creates Invoice row (idempotent on repeat)* · P0
- RZP-09** — *Invoice list renders on Billing page* · P1
- RZP-10** — *invoice pdfUrl opens hosted PDF* · P1
- RZP-11** — *Cancel-at-cycle-end preserves paid access* · P0
- RZP-12** — *Payment failed* → status *PAST\_DUE* · P0
- 

## 18. Super-admin (ADM)

- ADM-01** — *Only SUPERADMIN can access* `/super-admin` · P0
- ADM-02** — *Summary tiles show correct counts* · P1
- ADM-03** — *Org table search by name / slug* · P1
- ADM-04** — *Plan filter, status filter* · P2
- ADM-05** — *Change plan writes audit row* · P0
- ADM-06** — *Extend trial +7 / +14 / +30* · P1
- ADM-07** — *Suspend org — refuses Default Org* · P0
- ADM-08** — *Reactivate previously suspended org* · P1
- ADM-09** — *Recent audit log panel renders latest 40 actions* · P1
- ADM-10** — *Non-SUPERADMIN receives 403 for every* `/super-admin/*` *route* · P0
- ADM-11** — *Cross-tenant reads work only via runAsSystem* · P0



## 19. Impersonation (IMP)

**IMP-01 — Impersonate button visible in drawer · P1**

**IMP-02 — Cannot impersonate Default Org · P0**

**IMP-03 — Cannot impersonate org with no owner user · P0**

**IMP-04 — Impersonation returns valid tokens with `act` claim · P0**

**IMP-05 — Impersonation writes audit row · P0**

**IMP-06 — Original session stashed to sessionStorage · P1**

**IMP-07 — Banner shows across every page during impersonation · P0**

**IMP-08 — Return-to-admin restores original tokens and lands on `/super-admin` · P0**

**IMP-09 — Return-to-admin with lost stash falls back to `/login` · P1**

**IMP-10 — All actions during impersonation attributed to target user in normal audit; impersonation event owned by SUPERADMIN · P0**

## 20. Data & Privacy — DPDPA (DPP)

**DPP-01 — `/data-privacy` visible for OWNER + ADMIN only · P0**

**DPP-02 — Download all data — file naming convention `<slug>-export-<date>.json` · P1**

**DPP-03 — Export contains all 18 model families · P0**

**DPP-04 — Export scrubs passwordHash from users · P0**

**DPP-05 — Delete-my-org requires typing exact slug · P0**

**DPP-06 — Delete refuses Default Org · P0**

**DPP-07 — After delete, next login refused with status message · P0**

**DPP-08 — Terms + Privacy pages linked in footer + Data & Privacy · P1**

---

## 21. Customer portal (CST)

***CST-01 — Customer sees only own bookings · P0 (tenant isolation)***

***CST-02 — MyNewBookingModal loads branches (public endpoint) · P0***

***CST-03 — Booking created lands in admin Bookings · P0***

***CST-04 — Loyalty streak card accurate · P2***

***CST-05 — My Membership card shows plan + validity · P1***

***CST-06 — Refer & Earn page shows code + share buttons · P1***

---

## 22. Security cross-cutting (SEC)

See TEST\_PLAN.md §10.2 for tenant-isolation cases (iso-01 ... iso-15) — reproduced conceptually here:

***SEC-01 — JWT signature validated on every authed request · P0***

***SEC-02 — Expired JWT rejected 401 · P0***

***SEC-03 — Tampered JWT rejected 401 · P0***

***SEC-04 — Cannot access ADMIN routes as STAFF · P0***

***SEC-05 — Cannot access SUPERADMIN routes as any lesser role · P0***

***SEC-06 — CORS blocks unknown origins in production · P0***

***SEC-07 — Rate limiter throttles brute-force login attempts · P1***

***SEC-08 — Passwords hashed with bcrypt (cost 12) — never returned in any API · P0***

***SEC-09 — Refresh tokens revocable via logout · P1***

***SEC-10 — Cloudinary upload signature never exposed to client · P0***

***SEC-11 — All PATCH/DELETE on tenant models scoped by orgId server-side · P0***

***SEC-12 — Prisma queries never concatenate untrusted strings · P0***

***SEC-13 — Webhook endpoints not authed but verified by HMAC · P0***

***SEC-14 — Public routes (/public/\*) never return other tenants' data · P0***

***SEC-15 — Impersonation cannot be triggered by non-SUPERADMIN · P0***

---

*End of Test Case Catalogue*

## 3. Release Regression Checklist

# Release Regression Checklist

Run this end-to-end before promoting any build from staging to production. Every unchecked item blocks the release.

**Target environment:** staging (never prod) **Test data:** seeded QA Alpha (GROWTH) + QA Beta (STARTER) + QA Trial + QA Suspended orgs. **Estimated time:** ~90 minutes for one QA engineer.

## SMOKE\_SUITE (must pass in the first 10 min)

- ■ GET /api/v1/health/ready → { "status": "OK", "db": "up" }
- ■ Public marketing / renders — no console errors, Lighthouse Perf ≥ 85
- ■ Public marketing /pricing — currency toggle works, GST hint on INR
- ■ /start-salon — register a fresh OWNER, land on /onboarding
- ■ /onboarding — complete branch + service, land on /dashboard
- ■ /dashboard — 5 KPI tiles render with real numbers
- ■ /bookings — table + calendar + staff-grid all render, at least 1 row
- ■ /sales — POS opens, tap a product tile, quick-pay Cash → receipt appears
- ■ /whatsapp/messages/test (if WA configured) — delivers to test number
- ■ /billing — trial banner + usage bars render, WhatsApp CTA visible
- ■ /super-admin (as SUPERADMIN) — orgs list loads, summary tiles render
- ■ Impersonate an org → banner shows → **Return to admin** works

## 1. Authentication + tenant isolation

- ■ Login as QA Alpha admin — see only Alpha's data everywhere
- ■ Login as QA Beta admin — see only Beta's data everywhere
- ■ Login as QA Suspended admin — refused with "account suspended"
- ■ Refresh-token flow works after access token expires
- ■ Logout clears refresh token in DB
- ■ Direct URL to Beta's booking id from Alpha's session → 404/403

## 2. Signup + onboarding

- ■ Signup with an existing email → 400 with correct message
- ■ Signup succeeds with all 5 country flags → correct currency
- ■ Onboarding branch step creates Branch scoped to new org
- ■ Onboarding service step creates Service scoped to new org
- ■ Refreshing onboarding page mid-flow doesn't crash

---

## 3. Bookings

- ■ Create booking with registered customer
- ■ Create walk-in booking (name + phone only)
- ■ Overlap detection — 2nd booking on same staff+time refused
- ■ Status transitions PENDING → CONFIRMED → COMPLETED
- ■ Cancel booking with reason
- ■ Coupon applied at booking creation (percentage + fixed)
- ■ Member price auto-applied when customer has active membership
- ■ WhatsApp confirmation delivered (if configured)
- ■ Notification created for assigned staff
- ■ Calendar drag-reschedule works
- ■ Staff-grid view shows every staff column

---

## 4. Unified Sales POS

- ■ Product-only cart → checkout Cash
- ■ Service-only cart (walk-in) → checkout UPI
- ■ Mixed cart (product + service) → single checkout
- ■ Attach a pending booking → cart pre-fills customer + service
- ■ Duplicate-attach on same booking blocked
- ■ GST toggle adds 18% (server-side)
- ■ Discount applied and prorated
- ■ Receipt modal opens with correct totals
- ■ Print via `window.print()` produces 80mm thermal layout
- ■ Auto-print toggle persists across refresh
- ■ Barcode scanner (if hardware available) adds correct product
- ■ Legacy PAID booking no longer appears in "Collect from pending"

- ■ Stock decremented after product sale
- 

## 5. Staff / Branches / Products

- ■ Add staff on QA Beta (STARTER, cap 3) — 4th attempt shows 402 with upgrade
  - ■ Add branch on QA Beta — 2nd attempt shows 402
  - ■ Staff photo upload persists to Cloudinary
  - ■ Product low-stock badge appears when stock < 5
  - ■ Product expiry alert appears within N days
  - ■ Booking Link modal on Branches page copies URL
- 

## 6. Memberships / Coupons / Referrals

- ■ Membership plan create — 402 on QA Beta (STARTER)
  - ■ Membership plan create — success on QA Alpha (GROWTH)
  - ■ Member price auto-applied at POS
  - ■ Coupon usage limit enforced atomically (concurrent bookings can't over-use)
  - ■ Referral code on customer signup URL is tracked
  - ■ First completed booking awards 100 pts to both parties (idempotent)
  - ■ Referrals admin list — 402 on QA Beta
- 

## 7. WhatsApp

- ■ /messaging/status reflects configured state
  - ■ Test send delivers to verified number
  - ■ UsageMeter increments on successful send
  - ■ UsageMeter does NOT increment on API failure
  - ■ At quota cap: 402 with upgrade payload
  - ■ Booking flow never blocked by WA failure
- 

## 8. Billing

- ■ Trial banner shows correct days remaining
- ■ Trial banner amber  $\leq 3$  days, red on expiry
- ■ Usage bars for branches / staff / WA accurate
- ■ 402 toast wording clear + includes upgrade CTA
- ■ Sidebar crown icons on locked features (STARTER)
- ■ WhatsApp fallback CTA when Razorpay not configured
- ■ **If Razorpay configured:** subscribe flow returns short\_url and opens hosted checkout
- ■ **If Razorpay configured:** webhook signature verify works (send test event)
- ■ **If Razorpay configured:** subscription.charged flips org.plan
- ■ Invoice history renders after a successful payment

---

## 9. Super-admin

- ■ Non-SUPERADMIN cannot access /super-admin (client + server)
- ■ Orgs list filters (plan / status) work
- ■ Summary tiles match manual DB count
- ■ Change plan on an org — audit row created
- ■ Extend trial +7 → trialEndsAt increases by 7 days
- ■ Suspend an org — its users cannot log in
- ■ Cannot suspend Default Org (button disabled + server 400)
- ■ Audit log panel shows latest 40 events

---

## 10. Impersonation

- ■ Impersonate button visible on non-default, non-orphaned orgs
- ■ Impersonation returns tokens with act claim
- ■ Audit row created with action=impersonate
- ■ Purple banner shows on every page of impersonated session
- ■ **Return to admin** restores original session + lands on /super-admin
- ■ Lost stash → graceful fallback to /login

---

## 11. Data & Privacy (DPDPA)



- ■ Export downloads JSON with all 18 model families
- ■ passwordHash absent from every user in export
- ■ Delete-my-org requires exact slug match
- ■ Delete-my-org refuses Default Org
- ■ After delete, subsequent login refused
- ■ Terms + Privacy public pages render + linked in footer

---

## 12. Customer portal

- ■ CUSTOMER sees only own bookings on `/my/bookings`
- ■ New Booking modal loads branches (public endpoints, not admin)
- ■ Booking created appears in admin Bookings
- ■ Loyalty streak accurate
- ■ Refer & Earn shows code + share buttons

---

## 13. Cross-cutting non-functional

- ■ Lighthouse Accessibility  $\geq 90$  on Home, Pricing, Contact
- ■ Mobile viewport 360×640 renders without horizontal scroll
- ■ Print stylesheet only affects receipt
- ■ All P0 tenant-isolation cases (SEC + iso-\*) pass
- ■ API p95 latency < 600 ms on `/bookings?limit=50`

---

## 14. Migration + deploy

- ■ `bootstrap.ts` completed without errors on staging
- ■ All 15 migrations applied (0001 through 0015)
- ■ Rollback plan documented with prior SHA
- ■ Release notes committed to repo

---

## Sign-off

| Role             | Signature | Date |
|------------------|-----------|------|
| QA Lead          |           |      |
| Engineering Lead |           |      |
| Security         |           |      |
| Product Manager  |           |      |

*Release blocked if any P0 item above is unchecked.*

## 4. Defect Report Template

# Defect Report Template

Copy the block below into a new GitHub issue and fill it in. Anything unclear → file the bug anyway; the triage step will refine.

```
### Summary
<One sentence. What actually happens vs what was expected.>

### Severity
- [ ] P0 – Blocker (money, data, security, complete outage)
- [ ] P1 – High (major workflow broken, no workaround)
- [ ] P2 – Medium (workaround exists)
- [ ] P3 – Low (polish)

### Environment
- **Where:** Local / Preview / Staging / Production
- **URL:** https://...
- **Build:** git SHA (visible in footer or `/health`)
- **Browser + OS:** Chrome 131 on macOS 15.1
- **Viewport:** 1440x900 (or 360x640, etc.)

### Impersonation
- **Login role:** ADMIN / OWNER / STAFF / CUSTOMER / SUPERADMIN
- **Org slug:** qa-alpha
- **Session:** normal / impersonation active

### Steps to reproduce
1. Navigate to /bookings
2. Click ...
3. ...
(Every step short enough that anyone can re-run without asking.)

### Expected behaviour
<One sentence per assertion.>

### Actual behaviour
<What you saw. Include the exact toast text or error message.>

### Evidence
- [ ] Screenshot(s)
- [ ] Screen recording
- [ ] Network HAR
- [ ] Browser console logs
- [ ] Backend logs (`railway logs` snippet)

### Frequency
- [ ] Every time (100%)
- [ ] Often (>50%)
- [ ] Sometimes (10-50%)
- [ ] Rare (<10%)

### Impact
- **Users affected:** all / paid tier only / super-admins only / single org
- **Data at risk?** Yes / No – explain
- **Money involved?** Yes / No – explain

### Workaround
<Empty if none.>
```

```
### Suspected root cause / area
- Modules: bookings / sales / billing / super-admin / ...
- Ship: 4B / 5A / ...

### Related
- Blocks: #____
- Related: #____
```

## Filing rules

1. **One bug per issue.** If you see two, file two. Easier to triage and close.
2. **Title format:** [P0] [Sales] POS auto-print prints entire page instead of only receipt.
3. **P0 = wake-up-worthy.** If it's Sunday night and you filed a P0, ping the on-call in Slack.
4. **Reproducible steps or it doesn't exist.** A vague *"sometimes the dashboard is slow"* is a note, not a bug.
5. **PII stays out.** Replace real customer names / phones with placeholders in screenshots.
6. **Attach the git SHA.** Fixes get released against a specific build; the SHA is the ground truth.
7. **On close** — leave a one-line summary of the fix + the release it landed in.

## Triage SLA reminder (from TEST\_PLAN §12.2)

| Priority | Ack    | Fix on staging | In prod      |
|----------|--------|----------------|--------------|
| P0       | 30 min | 4 h            | Same day     |
| P1       | 4 h    | 1 day          | Next release |
| P2       | 1 day  | 5 days         | Bi-weekly    |
| P3       | 1 week | 30 days        | Next quarter |